

EXECUTIVE SUMMARY

GDPR Compliance Assessment – Juventus FC Digital Ecosystem

1. Introduction

This report presents a simulated Data Protection Impact Assessment (DPIA), supported by a full Record of Processing Activities (ROPA), data mapping exercise, and risk register, conducted for a hypothetical GDPR compliance review of the digital and operational data processing activities of Juventus FC.

The objective of this assessment is to evaluate the club's personal data processing activities in relation to the requirements of the General Data Protection Regulation (GDPR), identify associated privacy risks, and propose appropriate mitigation measures.

The scope includes fan engagement systems, ticketing operations, player performance monitoring, medical data processing, CCTV surveillance, and employee data processing systems.

2. Scope of Assessment

The assessment covers the following key processing areas:

- Digital fan engagement platforms (website, mobile applications, CRM systems)
- Ticketing and stadium access control systems
- CCTV surveillance within stadium environments
- Player biometric and performance tracking systems
- Medical and injury record management
- Human resources and payroll processing systems
- Vendor and third-party data processing arrangements

This assessment is based on publicly available information, inferred industry practices, and standard data protection frameworks.

3. Key Findings

The assessment identified several high-impact data processing activities, particularly in the areas of sports performance analytics and fan digital engagement.

3.1 High-Risk Processing Areas

- **Player biometric and performance monitoring** involving GPS tracking, heart rate data, and sleep analysis
- **Medical and injury records processing**, containing highly sensitive special category data under Article 9 GDPR
- **Fan behavioural profiling**, including tracking via cookies, mobile applications, and digital engagement platforms
- **CCTV surveillance systems** used for stadium security and public safety

3.2 Cross-Border Data Transfers

A significant portion of personal data is likely transferred to third-party service providers, including cloud hosting, analytics, and payment processors. These transfers may involve jurisdictions outside the European Economic Area (EEA), requiring appropriate safeguards such as Standard Contractual Clauses (SCCs).

4. Risk Overview

The following key risks were identified:

- Unauthorized access to sensitive medical and biometric data of players
- Excessive or disproportionate tracking of player performance metrics
- Lack of transparency in fan profiling and behavioral analytics
- Potential misuse or over-retention of CCTV footage
- Risks associated with third-party vendor security and cross-border data transfers
- Failure to comply with data retention and minimization principles

Overall, the risk profile of the organization is assessed as **Medium to High**, primarily driven by the sensitivity and scale of biometric and behavioral data processing.

5. Mitigation Measures

The following mitigation measures are recommended:

Technical Measures

- Encryption of all sensitive and special category data

- Pseudonymisation of biometric and performance data
- Multi-factor authentication for access to sensitive systems
- Secure cloud architecture with restricted access controls

Organisational Measures

- Role-based access control based on least privilege principles
- Regular staff training on GDPR compliance obligations
- Implementation of strict data retention schedules
- Vendor due diligence and Data Processing Agreements (DPAs)

Legal & Compliance Measures

- Use of Standard Contractual Clauses (SCCs) for international data transfers
- Updated privacy notices for transparency to data subjects
- Clear consent mechanisms for marketing and wearable tracking
- Formal DPIA review cycles for high-risk processing activities

6. Residual Risk

Following implementation of mitigation measures, the overall residual risk level is reduced to **Medium**, with certain high-risk areas (particularly biometric processing) requiring ongoing monitoring and periodic reassessment.

No processing activity has been identified as presenting an unacceptable risk that would require cessation; however, continuous governance is necessary due to the evolving nature of sports analytics and digital engagement technologies.

7. Conclusion

The assessment concludes that while Juventus FC operates within a complex and data-intensive environment, the majority of identified privacy risks can be effectively mitigated through robust technical, organisational, and legal safeguards.

Key areas requiring ongoing attention include player biometric monitoring, fan profiling practices, and cross-border data transfers involving third-party vendors.

With appropriate governance structures in place, the organisation can achieve a balanced approach between operational performance, commercial objectives, and compliance with GDPR requirements.

8. Final Statement

This project demonstrates applied knowledge of GDPR compliance frameworks, including data mapping, risk assessment, ROPA development, and DPIA execution, within a real-world inspired organisational context.